1. unauthorized vulnerability outside the approved scope:-

I would not exploit the vulnerability because the system is outside the authorized testing scope. Ethical hacking requires proper authorization, defined boundaries, and responsible disclosure.

First, I would stop further testing on that system and document the vulnerability without attempting to exploit it. Then, I would inform the client and request written authorization before conducting any additional tests. The engagement scope should also be clarified because a one-line email may not adequately define the permitted activities.

Ethical principles involved:-

* Authorization: test only systems explicitly approved by the client.
* non-maleficence:- Avoid actions that could cause harm or disrupt services.
* Responsibility:- report vulnerabilities responsibly.
* Integrity:- follow the agreed roles of engagement.

conclusion:-

A vulnerability discovered during testing does not automatically grant permission to exploit it.

Q. SQL injection in a production database containing financial data:-

I would prioritize protecting customer data and preventing damage. before exploiting the SQL injection vulnerability, I would review the rules of engagement and inform the client about the presence of real financial data.

Instead of accessing or modifying actual customer records, I would use a safe, non-destructive test to confirm the vulnerability. if further validation were necessary, I would request explict approvel and use a staging environment with synthetic data whenever possible.

Precautions to take:-

1. obtain written authorization and define the testing scope.
2. identify sensitive systems and data before testing.
3. prefer a staging environment or test database.
4. use non-destructive testing technique.
5. Avoid extracting, modifying, or deleting real customer data.
6. Establish backup, recovery and incident response procedure.

4. define emergency contacts and stop conditions.

Conclusion:-

The objective is to prove that the vulnerability exists without exposing financial information or disrupting business operations.

3. Accidental denial-of-service during a penetration test:-

To prevent a denial-of-service incident, I shave assessed the target capacity, identified production critical systems, and obtained approval for any tests that could affect availability. I should also have used conser-vative request rates, monitored server performance, and established clear stop conditions.

If an outage occurs, I would take the following steps:-

1. Stop testing immediately to prevent further disruption.
2. notify the client and the designed emergency contact.
3. Assist with recovery according to the agreed incident response procedure.
4. preserve evidence, including timestamps, logs, and the actions that triggered the outage.
5. Document that incident and provide an honest report of its cause and impact.

6. review the failure and recommend safeguards to prevent recurrence.

I would not attempt unapproved recovery actions or conceal the incident.

conclusion:

Ethical hackers are responsible for minimizing harm, reporting incidents promptly, and cooperating with the clients to restore normal operations.

4. Client requests a test without informing the IT department:

The request evades ethical, legal, and operational risks. Although the client may want to evaluate the IT teams real-world detection capabilities, uniformed testing could be mistaken for a genuine attack and trigger emergency responses or service disruptions.

To protect both parties, I would confirm that the client has the authority to approve the exercise and obtain written authorization from the appropiate decision-makers.

I would establish the following safeguards:

1. define testing scope, objectives, permitted techniques, and duration.
2. obtain written approval from authorized management.
3. identify an emergency contact who can stop the exercise.

4. Agree on escalation procedures if the test causes unexpected damage.
5. define prohibited activities, including actions that could endanger critical systems or customer data.
6. Establish procedures for securely recording and reporting the results.

For a realistic detection exercise, the IT team may remain unaware of the exact timing and techniques, while an unauthor-ized executive or designated control group retains the ability to intervence.

Conclusion:

A covert test can be ethical when it is properly authorized, carefully controlled, and designed to minimize harm. secrecy from the IT organizational authorization.

5. Red team Exercise vs vulnerability Assessment for bank:

A bank wants to test the security of its digital systems and physical branches.

1. Vulnerability Assessment:

A vulnerability assessment identifies weakness in the bank's systems. testers scan networks, check outdated software, and identify security problems they prepare a report and suggest solutions to fix vulnerabilities.

Example:-

Finding a weak password policy or outdated banking software.

2. Red team exercise:-

A red team exercise simulates real-world attacks to test how effectively the bank can detect and respond to threats. it may include authorized phising simulations, controlled digital attacks, and physical security testing.

Example:-

Testing whether the bank's security team detects a simulated phishing attack.

conclusion:-

A vulnerability assessment focuses on finding security weaknesses, whereas a red team exercise tests the bank's overall ability to prevent, detect, and respond to attacks. both require proper authorization and must follow ethical hacking principles.